

Bill of Materials (BOM) et Suivi de Sécurité

mobiTrace (TRACE & TRACE-SCAN)

Date de mise à jour : Juin 2026

Applications : TRACE (Plateforme centrale) & TRACE-SCAN (Satellite mobile) — 5 paquets Debian

Objectif : Inventaire exhaustif des dépendances pour le suivi des vulnérabilités (CVE) et la maintenance préventive.

Convention de lecture : fond vert = composant ajouté depuis Avril 2026 ; texte grisé italique = archivé (retiré du bundle actif).

1. ENVIRONNEMENT SYSTÈME (OS)

Composant	Version cible	Méthode d'installation	Rôle	Stratégie de mise à jour
Debian Linux	13 (Trixie)	Image système / ISO	Système d'exploitation hôte sécurisé.	apt-get update && apt-get upgrade réguliers (mensuel préconisé).

2. INFRASTRUCTURE & BACKEND (Serveur TRACE)

Composant	Version / Source	Méthode	Rôle	Suivi de sécurité
Nginx	Dépôts Debian 13	apt (trace-server)	Serveur Web (fichiers statiques) et Reverse Proxy (TLS, routage API, rate limiting).	Gestion automatique via apt. Surveiller les CVE Nginx.
PostgreSQL	v17 (Dépôts Debian)	apt (trace-server)	Base de données relationnelle. Gère l'auth (pgcrypto) et la logique métier (Triggers/RPC).	Gestion automatique via apt. Surveiller les failles PostgreSQL.
PostgREST	v12.x (Binaire statique)	Copie manuelle (/usr/local/bin/)	Middleware API. Transforme le schéma SQL en API RESTful.	Manuel : surveiller les releases sur le GitHub officiel de PostgREST.
OpenSSL	Dépôts Debian 13	apt (trace-server)	Génération des certificats TLS/SSL locaux.	Gestion automatique via apt.
Fail2Ban	Dépôts Debian 13	apt (trace-server)	Protection anti-bruteforce. Surveille les codes 401/429 sur POST /api/rpc/login (5 tentatives → ban 1h).	Gestion automatique via apt. Surveiller les CVE Fail2Ban.

2bis. MODULES D'INFRASTRUCTURE OPTIONNELS (Paquets Debian)

Ces composants sont installés uniquement si les paquets satellites correspondants sont déployés.

Composant	Version / Source	Paquet Debian	Rôle	Suivi de sécurité
CUPS	Dépôts Debian 13	trace-zebra-printer	Serveur d'impression. Gère la file d'attente vers l'imprimante Zebra (port RAW 9100).	Gestion automatique via apt. Surveiller les CVE CUPS.
Python 3 + Flask	Flask v3.0.2 (Dépôts Debian)	trace-zebra-printer	Microservice d'impression ZPL (/opt/mobitrace-print/print_api.py). Expose les routes /imprimer-zpl, /imprimante/status, /action, /config.	apt. Surveiller CVE Flask/Werkzeug.
Gunicorn	v20.1.0 (Dépôts Debian)	trace-zebra-printer	Serveur WSGI. Sert le microservice Flask avec 2 workers sur 127.0.0.1:5050.	apt. Surveiller CVE Gunicorn.
NFS (Serveur)	nfs-kernel-server (Dépôts Debian)	trace-backup-server	Partage réseau NFS sécurisé pour la réception des dumps PostgreSQL (/var/nfs/backupTRACE).	apt. Contrôler l'accès par IP via /etc/exports.
NFS (Client)	nfs-common (Dépôt Debian)	trace-backup-client	Montage automatique du partage NFS distant (/mnt/savetrace) via systemd automount.	apt.
Postfix + mailutils	Dépôts Debian 13	trace-backup-server-survey	Envoi d'alertes email quotidiennes (rapport de sauvegarde). Configurable via relais SMTP interne.	apt. Sécuriser la configuration Postfix (relayhost, pas de relay ouvert).

3. FRONTEND — PLATEFORME CENTRALE (TRACE)

Composant	Version	Fichier / Intégration	Rôle	Suivi de sécurité
Vanilla JS	N/A	Natif (app.js ~2500 lignes)	Logique métier de l'application SPA (app.js v2.1).	Revue de code interne (SAST). Focus sur escapeHTML().
DSFR	v1.14.3	Local (/dsfr/)	Système de Design de l'État (UI/UX, Accessibilité).	Surveiller le dépôt GitHub GouvernementFR/dsfr.
bwip-js	v4.x	Local (/utils/bwip-js-min.js)	Génération de codes-barres DataMatrix pour les étiquettes Zebra (zebra2.html). Bibliothèque active retenue pour ce module.	Mise à jour manuelle en cas de CVE. Surveiller le dépôt metafloor/bwip-js.
JsBarcode	v3.11.5	Local (/utils/JsBarcode.all.min.js)	Génération de codes-barres Code128/EAN. Utilisée uniquement par l'ancien générateur zebra-codebar-generator.html, non lié depuis l'interface actuelle (remplacé par bwip-js + DataMatrix).	Non actif en production. Conserver tant que zebra-codebar-generator.html reste présent dans utils/.
jsPDF	v2.5.1	Local (/utils/jspdf.umd.min.js)	Génération des Procès-Verbaux de mise au rebut (PDF côté client). Format UMD (remplace l'ancien bundle CommonJS).	Mise à jour manuelle du fichier dans /utils/ en cas de CVE.

jsPDF-AutoTable	v3.5.25 — ARCHIVÉ	archives/ (retiré du bundle actif)	Extension jsPDF pour les tableaux du PV. Fonctionnalité désormais gérée nativement.	Non actif. Conserver en archives pour référence.
QR Code Styling	v1.6.0-rc.1 — ARCHIVÉ	archives/ (retiré du bundle actif)	Rendu des planches d'étiquettes QR Codes personnalisées. Remplacé par les générateurs Zebra ZPL.	Non actif. Conserver en archives pour référence.
qrcode.min.js	— ARCHIVÉ	archives/ (retiré du bundle actif)	Génération de QR codes. Remplacé par JsBarcode + ZPL.	Non actif.

Outils front-end (utils/)

Fichier HTML	Statut	Rôle
zebra2.html	ACTIF — NOUVEAU	Générateur d'étiquettes ZPL actuel (DataMatrix, via bwip-js). Lié depuis Administration → Édition étiquettes.
zebra-codebar-generator.html	PRÉSENT — NON LIÉ	Ancien générateur de codes-barres ZPL (Code128, via JsBarcode). Toujours présent dans utils/ mais plus référencé depuis l'interface — remplacé par zebra2.html.
zebra-codebar-generator-finetune.html	PRÉSENT — NON LIÉ	Version avancée de l'ancien générateur (réglages fins). Non référencée depuis l'interface actuelle.
codebar-generator.html	ARCHIVÉ	Ancien générateur de codes-barres.
qrcode-generator.html	ARCHIVÉ	Ancien générateur de QR codes.
copytop-qrcode-generator.html	ARCHIVÉ	Générateur QR codes format copytop.
etiquettes-generator.html	ARCHIVÉ	Générateur de planches d'étiquettes.

4. APPLICATION SATELLITE MOBILE (TRACE-SCAN)

L'application satellite est conçue pour le mode "Offline-First" (PWA), imposant l'hébergement local de toutes ses ressources.

Composant	Version	Intégration	Rôle	Suivi de sécurité
PWA Engine	HTML5/JS	Natif	Interface de scan et gestion des exports (index.html).	Revue de code interne.
Service Worker	v1.1	Natif (sw.js)	Gestion du cache et fonctionnement hors-ligne (Offline).	Revue de code interne.
html5-qrcode	v2.3.8 (ou +)	Local (/utils/)	Bibliothèque de lecture des QR Codes via caméra mobile.	Critique : surveiller les CVE sur mebjas/html5-qrcode.
DSFR (Light)	v1.14.3	Local	Identité visuelle (Header Marianne).	Cohérence avec l'application centrale.

5. PROCESSUS DE MAINTENANCE ET AUDIT

5.1. Veille sur les dépendances

Contrairement aux projets Node.js, mobiTrace n'utilise pas de package-lock.json. La veille doit donc être proactive :

- **Système** : Relancer le script `intrace.sh` sur des images Debian à jour.
- **Bibliothèques JS actives** : Les fichiers dans `/utils/` (`bwip-js`, `jspdf.umd.min.js`) doivent être remplacés manuellement si une vulnérabilité majeure est publiée (veille GitHub). `JsBarcode` reste présent mais n'est plus utilisé par l'interface actuelle.
- **Bibliothèques archivées** : Les fichiers dans `/utils/archives/` ne sont plus actifs en production. Ils peuvent être supprimés définitivement après validation que leurs fonctionnalités sont couvertes par les nouveaux outils Zebra.
- **Modules optionnels** : `Flask`, `Gunicorn`, `CUPS` (`trace-zebra-printer`) et `Postfix` (`trace-backup-server-survey`) sont gérés via `apt`. Surveiller les CVE `Flask/Werkzeug` en priorité.

5.2. Sécurité du code source (Audit Statique)

- **Protection XSS** : L'utilisation de `escapeHTML()` dans `app.js` est obligatoire pour toute injection de données provenant de la base de données ou de l'utilisateur dans le DOM.
- **Intégrité PWA** : Le fichier `manifest.json` et le `sw.js` de `TRACE-SCAN` doivent être servis via `HTTPS` uniquement (garanti par la configuration `Nginx`).
- **Microservice Zebra** : Les routes `/imprimer-zpl`, `/imprimante/action` et `/imprimante/config` sont protégées par authentification `JWT` via le bloc `auth_request /_zebra-auth` de `Nginx`. Aucun accès direct au port 5050 (`Gunicorn` écoute sur `127.0.0.1` uniquement).
- **Sudoers Zebra** : `/etc/sudoers.d/mobitrace-print` accorde à `www-data` l'exécution sans mot de passe de `lpadmin`, `cupsenable`, `cupsdisable`, `cancel` uniquement. Restreindre à ces commandes et auditer régulièrement.

5.3. Gestion du patrimoine logiciel

- **Licence** : Creative Commons (CC BY-NC-SA).
- **Dépôt** : GitHub (Public). Permet l'utilisation d'outils d'analyse automatique (type `Dependabot` ou `CodeQL`) même sur du code `Vanilla JS`.
- **Paquets Debian** : Les 5 paquets (`.deb`) sont versionnés `1.0.0`. Incrémenter le numéro de version à chaque modification des scripts `postinst` ou des fichiers embarqués, et régénérer les `.deb` via `build.sh`.